

AURA Dealership OS

Google Cloud Platform — Enterprise Architecture (DEV & PROD)

Prepared July 31, 2026 · Region: southamerica-east1 (São Paulo) · Users: Guyana only · ~1,000 transactions/day

Workloads: two React web applications (AURA dealer app, Realm super-admin), a Node/Express API, and server-side AI agents (sessions, feedback, conversation history, document-extracted data). Requirements: VM-based compute with autoscaling and high uptime, API Gateway, load balancing, NoSQL for agent data, PostgreSQL for OLTP, cache, observability, Secret Manager, Google SSO, and strict security hardening (geo-fenced to Guyana).

TRAFFIC FLOW

Users (Guyana) → HTTPS → Global External Load Balancer + Cloud Armor WAF → (a) static frontends from Cloud Storage + Cloud CDN, (b) /api/* via API Gateway → autoscaled Managed Instance Group (Node API) → Cloud SQL / Firestore / Memorystore Redis. All VMs are private-IP only; outbound via Cloud NAT; admin access via IAP tunnels.

PROJECT & ENVIRONMENT SEGREGATION

Item	DEV (aura-dev)	PROD (aura-prod)
GCP project	aura-dev — isolated billing, IAM, quotas	aura-prod — hard blast-radius isolation
Purpose	Active product build; high-uptime dev/QA	Customer-facing production
Deploys	CI deploys on merge to main	CI-only with manual approval gate; Binary Authorization (signed images only)
Human access	Developers via IAP + OS Login	No standing access; break-glass short-lived elevation only
Domains	dev.yourdomain.gy	app.yourdomain.gy, realm.yourdomain.gy

DEV Environment — Resource List

Resource	Specification	Reason
Compute Engine MIG (Node API)	e2-standard-2 (2 vCPU / 8 GB), min 2 / max 4, multi-zone (southamerica-east1-b/c), Shielded VM, container-based	Medium-sized for active product development; min 2 across zones keeps DEV highly available during deploys and zone incidents; autoscaling absorbs test load spikes.
Global HTTPS Load Balancer	Managed TLS cert, HTTP!HTTPS redirect	Same entry architecture as PROD so behaviour is identical; terminates TLS at Google edge.
Cloud Armor	Same policy set as PROD, preview (log-only) mode	Tune WAF/geo/rate rules against real traffic without blocking developers.
API Gateway	OpenAPI spec from the repo; JWT validation	Validates the gateway contract early so PROD holds no surprises.
Cloud Storage + CDN (frontends)	2 buckets (AURA, Realm), uniform access	Serve SPA builds without occupying VM capacity.
Cloud SQL PostgreSQL	db-custom-1-3840, single-zone, private IP, 7-day backups	Full-featured OLTP for dev/QA at minimum cost; single-zone acceptable since data is reproducible.
Firestore (Native)	Default DB in aura-dev, relaxed TTLs	Agent NoSQL (sessions, feedback, conversations, doc extractions) identical API to PROD.
Memorystore Redis	Basic tier, 1 GB, AUTH + TLS	Cache/queues/idempotency parity with PROD; Basic tier saves cost.
Cloud NAT + Cloud Router	1 gateway	Outbound internet (LLM APIs, Twilio, Gmail) with zero inbound exposure.
Secret Manager	Per-env secrets, SA-scoped access	Dev keys fully separated from production credentials.
Identity Platform (Google SSO)	Google provider, domain-restricted	Same login flow as PROD for realistic testing.
Observability stack	Cloud Logging/Monitoring/Trace/Error Reporting, uptime check on /api/health	Catch regressions and latency issues before they ship.
Artifact Registry	Shared with CI; vulnerability scanning	Single source of scanned, versioned images promoted DEV != PROD.
Web Security Scanner	Weekly scan against DEV URL	Automated OWASP probing where it is safe to probe.

Estimated DEV cost: ~US\$300–450 / month (driven by 2× e2-standard-2, Cloud SQL, Redis).

PROD Environment — Resource List

Resource	Specification	Reason
Compute Engine MIG (Node API)	e2-standard-2, min 2 / max 6, multi-zone, Shielded VM, autoscale on CPU 60% + LB capacity, rolling updates (surge 1 / unavailable 0)	High uptime: zero-downtime deploys, zonal-failure tolerance, headroom to scale 3× instantly; 1,000 tx/day uses a fraction of this.
Global HTTPS Load Balancer	Managed certs, HSTS, HTTP!HTTPS	Single hardened entry point; Google-edge DDoS absorption.
Cloud Armor (enforced)	Geo-allowlist GY; OWASP preconfigured rules (SQLi/XSS/LFI/RCE); 60 req/min per IP, 10 req/min on /api/auth/* and agent endpoints; reCAPTCHA Enterprise on login	Guyana-only geo-fence removes ~99% of attack surface; rate caps stop brute force and LLM cost abuse.
API Gateway	OpenAPI contract, JWT validation, per-consumer API keys/quotas	Schema-validated API surface; controlled machine-to-machine access (e.g. bank connector callbacks).
Cloud Storage + CDN (frontends)	Versioned buckets, CMEK	Fast, cheap, low-attack-surface SPA delivery.
Cloud SQL PostgreSQL	db-custom-2-8192, REGIONAL (HA auto-failover), PITR, 30-day backups + cross-region copies to us-east1, deletion protection, CMEK, private IP + IAM DB auth	OLTP system of record. HA meets uptime target; PITR/ cross-region backups recover from bad deploys, deletion, ransomware; unreachable from the internet.
Firestore (Native)	TTL policies (e.g. 90-day session expiry), daily managed backups, server-only access (rules deny client SDK)	Agent NoSQL store; serverless scaling and zero ops; TTL enforces data hygiene on conversational data.
Memorystore Redis	Standard tier (HA replica), 1 GB, AUTH + in-transit TLS	Cache/sessions/queues with automatic failover to protect uptime.
Cloud Storage (documents)	Signed URLs only, uniform access, object versioning, CMEK, optional DLP scans	Customer document uploads with fail-closed access control.
Cloud NAT + Cloud Router	1 gateway, logging on	No public IPs on any VM; audited outbound only.
Secret Manager	CMEK, 90-day rotation schedules, per-SA access, access audit logs	All credentials centralized, rotated, and audited; nothing in code or metadata.
Identity Platform (Google SSO)	OIDC, Workspace-domain restricted (hd claim verified server-side)	Staff single sign-on; app RBAC (explicit-view model) stays in Postgres.
IAP on Realm admin app	Google-enforced allowlist group	Independent second auth wall on the super-admin surface — an app bug cannot expose it.
VPC Service Controls	Perimeter around SQL, Firestore, GCS, Secret Manager	Blocks data exfiltration even if credentials are stolen.
Binary Authorization	Only CI-signed images from Artifact Registry may run	Supply-chain defense: a compromised laptop cannot deploy to PROD.
Observability	Logging (30d + 400-day locked GCS sink), Monitoring dashboards & alerts (5xx>2%, p95>1.5s, SQL disk>80%, login-failure and WAF-deny spikes, budget), Trace, Error Reporting, multi-region uptime checks	Detect outages and attacks in minutes; tamper-proof audit trail for forensics/compliance.
Security Command Center	Standard tier	Continuous misconfiguration and exposure detection.

Estimated PROD cost: ~US\$600–900 / month. All infrastructure is defined in Terraform (state in GCS, one workspace per environment); GitHub Actions deploys via keyless Workload Identity Federation with a manual approval gate before PROD.

DEV vs PROD — At a Glance

Dimension	DEV	PROD
API VMs	e2-standard-2 × 2–4, multi-zone	e2-standard-2 × 2–6, multi-zone, Binary Auth
Cloud SQL	Single-zone, 7-day backups	Regional HA, PITR, 30-day + cross-region backups, CMEK
Firestore	Own DB, relaxed TTL	TTL + daily backups, VPC-SC perimeter
Redis	Basic 1 GB	Standard (HA) 1 GB
Cloud Armor	Preview / log-only	Enforced: GY geo-fence, OWASP, rate limits, reCAPTCHA
IAP on Realm	Optional	Required
Access	Devs via IAP + OS Login; CI deploys	CI-only deploys; no standing human access
Secrets	Dev-only keys	CMEK + 90-day rotation + access audit
Est. cost / month	~US\$300–450	~US\$600–900

MIGRATION ORDER

1) Terraform the DEV project end-to-end and deploy the API container to the DEV MIG. 2) Migrate data: pg_dump/restore into Cloud SQL; move agent persistence to Firestore. 3) Wire Secret Manager and Google SSO in DEV; run regression suites. 4) Stamp out PROD from the same Terraform with prod tfvars, enforce Cloud Armor, cut DNS over.